



ZAP Scanning Report

Site: <http://localhost:3100>

Generated on Thu, 6 Aug 2026 02:28:38

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	0
Low	5
Informational	9
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	24
Info	Informational		Percentage of network failures	23 %
Info	Informational	http://localhost:3100	Percentage of responses with status code 2xx	92 %
Info	Informational	http://localhost:3100	Percentage of responses with status code 4xx	8 %
Info	Informational	http://localhost:3100	Percentage of endpoints with content type application/javascript	65 %
Info	Informational	http://localhost:3100	Percentage of endpoints with content type image/svg+xml	8 %
Info	Informational	http://localhost:3100	Percentage of endpoints with content type text/css	13 %
Info	Informational	http://localhost:3100	Percentage of endpoints with content type text/html	13 %
Info	Informational	http://localhost:3100	Percentage of endpoints with method GET	100 %
Info	Informational	http://localhost:3100	Count of total endpoints	23

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	1
Cross-Origin-Opener-Policy Header Missing or Invalid	Low	1
Cross-Origin-Resource-Policy Header Missing or Invalid	Low	Systemic
Permissions Policy Header Not Set	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic
Base64 Disclosure	Informational	2
Modern Web Application	Informational	5
Non-Storable Content	Informational	3
Sec-Fetch-Dest Header is Missing	Informational	3
Sec-Fetch-Mode Header is Missing	Informational	3
Sec-Fetch-Site Header is Missing	Informational	3
Sec-Fetch-User Header is Missing	Informational	3
Storable and Cacheable Content	Informational	Systemic
Storable but Non-Cacheable Content	Informational	2

Alert Detail

Low	Cross-Origin-Embedder-Policy Header Missing or Invalid
Description	Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).
URL	http://localhost:3100
Node Name	http://localhost:3100
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14

Plugin Id	90004
Low	Cross-Origin-Opener-Policy Header Missing or Invalid
Description	Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.
URL	http://localhost:3100
Node Name	http://localhost:3100
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	same-origin-allow-popups
Other Info	
Instances	1
Solution	Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Cross-Origin-Resource-Policy Header Missing or Invalid
Description	Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.
URL	http://localhost:3100/_next/static/chunks/webpack-4419c03630deb7a2.js
Node Name	http://localhost:3100/_next/static/chunks/webpack-4419c03630deb7a2.js
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/_next/static/css/86498b921adc386d.css
Node Name	http://localhost:3100/_next/static/css/86498b921adc386d.css
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	

Evidence	
Other Info	
URL	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Node Name	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/icon.svg
Node Name	http://localhost:3100/icon.svg
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/nycu-favicon.svg
Node Name	http://localhost:3100/nycu-favicon.svg
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages. 'same-site' is considered as less secured and should be avoided. If resources must be shared, set the header to 'cross-origin'. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Permissions Policy Header Not Set
-----	-----------------------------------

Description	Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.
URL	http://localhost:3100/_next/static/chunks/1145-4fbb163c2690db8d.js
Node Name	http://localhost:3100/_next/static/chunks/1145-4fbb163c2690db8d.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/_next/static/chunks/2954-26bd28d04d34bf73.js
Node Name	http://localhost:3100/_next/static/chunks/2954-26bd28d04d34bf73.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/_next/static/chunks/app/layout-3dee0c42e78f5d63.js
Node Name	http://localhost:3100/_next/static/chunks/app/layout-3dee0c42e78f5d63.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/_next/static/chunks/main-app-f3336e172256d2ab.js
Node Name	http://localhost:3100/_next/static/chunks/main-app-f3336e172256d2ab.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/_next/static/chunks/webpack-4419c03630deb7a2.js
Node Name	http://localhost:3100/_next/static/chunks/webpack-4419c03630deb7a2.js
Method	GET
Parameter	

Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy https://developer.chrome.com/blog/feature-policy/ https://scotthelme.co.uk/a-new-security-header-feature-policy/ https://w3c.github.io/webappsec-feature-policy/ https://www.smashingmagazine.com/2018/12/feature-policy/
CWE Id	693
WASC Id	15
Plugin Id	10063

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:3100/_next/static/chunks/webpack-4419c03630deb7a2.js
Node Name	http://localhost:3100/_next/static/chunks/webpack-4419c03630deb7a2.js
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3100/_next/static/css/86498b921adc386d.css
Node Name	http://localhost:3100/_next/static/css/86498b921adc386d.css
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Node Name	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css

Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3100/icon.svg
Node Name	http://localhost:3100/icon.svg
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3100/nycu-favicon.svg
Node Name	http://localhost:3100/nycu-favicon.svg
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational

Base64 Disclosure

[illegible]

Instances	2
Solution	Manually confirm that the Base64 data does not leak sensitive information, and that the data cannot be aggregated/used to exploit other vulnerabilities.
Reference	https://projects.webappsec.org/w/page/13246936/Information%20Leakage
CWE Id	319
WASC Id	13
Plugin Id	10094

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://localhost:3100
Node Name	http://localhost:3100
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/4bd1b696-100b9d70ed4e49c1.js" async="" nonce="4L3JfvQzp47EYZCEf3OX+g=="></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3100
Node Name	http://localhost:3100
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/4bd1b696-100b9d70ed4e49c1.js" async="" nonce="OUoXPwQuL6o9w3yJwYh8XQ=="></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3100/
Node Name	http://localhost:3100/
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/4bd1b696-100b9d70ed4e49c1.js" async="" nonce="YtzNXqbdJLh2HZMjJt2Ayg=="></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3100/robots.txt
Node Name	http://localhost:3100/robots.txt
Method	GET

Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/4bd1b696-100b9d70ed4e49c1.js" async="" nonce="rr6nzp0Wqs+7zQl8yZ4vjg=="></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3100/sitemap.xml
Node Name	http://localhost:3100/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/4bd1b696-100b9d70ed4e49c1.js" async="" nonce="ESrl2hEZYk9AM5WtWN+kRg=="></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	5
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Non-Storable Content
Description	The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.
URL	http://localhost:3100
Node Name	http://localhost:3100
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://localhost:3100/robots.txt
Node Name	http://localhost:3100/robots.txt
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://localhost:3100/sitemap.xml

Node Name	http://localhost:3100/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
Instances	3
Solution	The content may be marked as storable by ensuring that the following conditions are satisfied: The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable) The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood) The "no-store" cache directive must not appear in the request or response header fields For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives) In addition to the conditions above, at least one of the following conditions must also be satisfied by the response: It must contain an "Expires" header field It must contain a "max-age" response directive For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive It must contain a "Cache Control Extension" that allows it to be cached It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Informational	Sec-Fetch-Dest Header is Missing
Description	Specifies how and where the data would be used. For instance, if the value is audio, then the requested resource must be audio data and not any other type of resource.
URL	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Node Name	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Method	GET
Parameter	Sec-Fetch-Dest

Attack	
Evidence	
Other Info	
URL	http://localhost:3100/icon.svg
Node Name	http://localhost:3100/icon.svg
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/nycu-favicon.svg
Node Name	http://localhost:3100/nycu-favicon.svg
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Dest header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Dest
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Mode Header is Missing
Description	Allows to differentiate between requests for navigating between HTML pages and requests for loading resources like images, audio etc.
URL	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Node Name	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/icon.svg
Node Name	http://localhost:3100/icon.svg
Method	GET
Parameter	Sec-Fetch-Mode

Attack	
Evidence	
Other Info	
URL	http://localhost:3100/nycu-favicon.svg
Node Name	http://localhost:3100/nycu-favicon.svg
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Mode header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Mode
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Site Header is Missing
Description	Specifies the relationship between request initiator's origin and target's origin.
URL	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Node Name	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/icon.svg
Node Name	http://localhost:3100/icon.svg
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/nycu-favicon.svg
Node Name	http://localhost:3100/nycu-favicon.svg
Method	GET
Parameter	Sec-Fetch-Site

Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Site header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Site
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-User Header is Missing
Description	Specifies if a navigation request was initiated by a user.
URL	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Node Name	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/icon.svg
Node Name	http://localhost:3100/icon.svg
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	http://localhost:3100/nycu-favicon.svg
Node Name	http://localhost:3100/nycu-favicon.svg
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-User header is included in user initiated requests.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-User
CWE Id	352
WASC Id	9

Plugin Id	90005
-----------	-----------------------

Informational	Storable and Cacheable Content
Description	The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	http://localhost:3100/_next/static/chunks/2954-26bd28d04d34bf73.js
Node Name	http://localhost:3100/_next/static/chunks/2954-26bd28d04d34bf73.js
Method	GET
Parameter	
Attack	
Evidence	max-age=31536000
Other Info	
URL	http://localhost:3100/_next/static/chunks/main-app-f3336e172256d2ab.js
Node Name	http://localhost:3100/_next/static/chunks/main-app-f3336e172256d2ab.js
Method	GET
Parameter	
Attack	
Evidence	max-age=31536000
Other Info	
URL	http://localhost:3100/_next/static/chunks/webpack-4419c03630deb7a2.js
Node Name	http://localhost:3100/_next/static/chunks/webpack-4419c03630deb7a2.js
Method	GET
Parameter	
Attack	
Evidence	max-age=31536000
Other Info	
URL	http://localhost:3100/_next/static/css/86498b921adc386d.css
Node Name	http://localhost:3100/_next/static/css/86498b921adc386d.css
Method	GET
Parameter	
Attack	
Evidence	max-age=31536000
Other Info	
URL	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css

Node Name	http://localhost:3100/_next/static/css/f6de2bba3bf22cdd.css
Method	GET
Parameter	
Attack	
Evidence	max-age=31536000
Other Info	
Instances	Systemic
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Informational	Storable but Non-Cacheable Content
Description	The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.
URL	http://localhost:3100/icon.svg
Node Name	http://localhost:3100/icon.svg
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
URL	http://localhost:3100/nycu-favicon.svg
Node Name	http://localhost:3100/nycu-favicon.svg
Method	GET
Parameter	
Attack	
Evidence	max-age=0

Other Info	
Instances	2
Solution	
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Sequence Details

With the associated active scan results.